

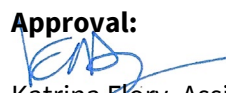


DAS Policy

Information Security and Privacy Awareness Training

No:
2100-05

Effective:
March 5, 2024

Approval:

Katrina Flory, Assistant Director/State CIO

I. Purpose

Information security and privacy awareness training is necessary so that **Organizational Users** of Ohio Department of Administrative Services (**DAS-Managed Information Systems**) understand their responsibilities to protect state systems and the information they contain.

The first occurrence of the word in the policy body outside of a title or heading is in bold, italic type, and is hyperlinked to the definition in Section IV. In addition, references to National Institute of Standards in Technology (NIST) Special Publication (SP) 800-53 family identifiers and control numbers are provided in parentheses next to requirement headers, where applicable. The requirements of the NIST SP 800-53 Awareness and Training (AT) control family are addressed in this policy.

II. Scope

The scope of this policy includes DAS-Managed Information Systems, **Service Owners**, managers of DAS business units, and those who use or administer such systems. This policy is not intended for the general population that accesses State of Ohio government services or applications.

III. Policy

DAS established an information security and privacy awareness training program to assure that all Organizational Users, who use or operate DAS-Managed Information Systems understand and adhere to all IT security policies.

- A. **Basic Information Security and Privacy Awareness Training (AT-2):** DAS programs, with support from the DAS Office of Information Security and Privacy (OISP), shall provide ongoing **Basic Information Security and Privacy Awareness Training** for all Organizational Users.

Additional training may also be prescribed based on the data an individual has access to, either explicitly or incidentally, as a result of their job functions. Examples include:

1. **Confidential Personal Information (CPI)** (Section 1347.15 of the Ohio Revised Code).
2. Criminal Justice Information (CJI).
3. Federal Educational Rights and Privacy Act (FERPA) Information.
4. Federal Tax Information (FTI).
5. Payment Card Industry (PCI) Information.
6. Personal Health Information (PHI) or Health Insurance Portability and Accountability Act (HIPAA) Information.
7. Social Security Administration (SSA) Information.

- B. **Role-Based Security and Privacy Training (AT-3)**: In accordance with Ohio Administrative Policy IT-15, "Information Security and Privacy Awareness Training," DAS identified the following job functions that require additional ***Role-Based Security and Privacy Training***:

1. Business managers and senior executives
2. Application developers, system administrators, and database administrators
3. Desktop support
4. Customer Service Center representatives (help desk personnel)

DAS OISP shall determine the specific nature and frequency of additional information security and privacy awareness training.

- C. **Information Security and Privacy Awareness Training Records (AT-4)**: General information security and privacy awareness training records shall be maintained in accordance with Ohio Administrative Policy IT-15, "Information Security and Privacy Awareness Training." State records retention schedules shall be followed for all training records.

IV. Definitions

- A. Basic Information Security and Privacy Awareness Training. The purpose of this type of training is for the participant to gain a basic understanding of the need for information security and privacy and the actions that he/she can take to maintain security and privacy and respond to suspected incidents. This training also increases awareness regarding the importance of operations security.

- B. Confidential Personal Information (CPI). Personal information that falls within the scope of Section 1347.15 of the Ohio Revised Code and that an agency is prohibited from releasing under Ohio's public records law.
- C. DAS-Managed Information System. Information systems that reside in facilities or infrastructure managed by DAS OIT personnel. Primary responsibility for managing these systems may be assigned to DAS OIT personnel or other outside entities.
- D. Organizational User. An Organizational User is anyone who is an employee of the state or is otherwise authorized to work on behalf of the state, and who has a need to access State of Ohio IT systems and has secured agency authorization for such access. The organizational identifier will help to distinguish the individual during the authentication process. Examples of resources that may fall into this category include full-time employees, part-time employees, seasonal employees, temporary contract workers, independent contractors or consultants, volunteers or unpaid interns. The Organizational User identifier category may also include university and federal government resources.
- E. Role-Based Security and Privacy Training. Role-based training strives to produce relevant and needed security and privacy knowledge and skills within the workforce. Role-Based Security and Privacy Training supports competency development and helps personnel understand and learn how to better perform their specific security or privacy role, which ultimately achieves more secure and protected information and systems.
- F. Service Owner. A Service Owner is responsible for the delivery (design, performance, integration), continual improvement and management of assigned IT services.

V. Authority

ORC 125.18

VI. Resources

Document Name	Location
NIST Special Publication 800-53, Security and Privacy Controls for Federal Information Systems and Organizations	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf
Ohio IT Standard ITS-SEC-02 Security Controls Framework	https://das.ohio.gov/technology-and-strategy/policies
State of Ohio Administrative Policy IT-15 Information Security and Privacy Awareness Training	https://das.ohio.gov/technology-and-strategy/policies

Document Name	Location
DAS Policy 700-01 Information Technology Resource Usage	https://das.ohio.gov/technology-and-strategy/policies

VII. Inquiries

Direct inquiries about this policy to:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street, 39th Floor
Columbus, Ohio 43215

614-644-6860 | state.isp@das.ohio.gov

DAS Policies may be found online at
<https://das.ohio.gov/technology-and-strategy/policies>

VIII. Revision History

This policy shall be reviewed no less than every two years and updated as needed.

Date	Description of Change
12/01/2009	New policy for DAS, replaces OIT policy dated 11/02/07.
12/05/2012	Policy reissued under Director Robert Blair
08/07/2018	Updated the requirements and terminology to align with the current DAS IT security awareness and training process.
01/19/2021	Incorporated privacy requirements into the policy. The term “Organizational User” was applied more consistently to clarify the scope. References, definitions and branding were modified to reflect current practices.
06/09/2021	Conducted routine maintenance review of citations and references.
03/05/2024	Updated the policy template. Added a revision history review frequency statement.